LABORATUVAR 3 · ARMINOKS SÜT OTOMATI

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = **L × S × E** (her biri 1–3). Kural: **S=3 ise skor düşük olsa bile senaryo öne alınır** — insana zarar görünür kalır.

Arminoks bağlamı: Kapılar LAB2'deki G tablosundan gelir: uzak servis (G01), yerel servis ekranı (G02), USB (G03), servis paketi / bakım projesi (G04), kontrolör yazma arayüzü (G05). Fiziksel sonuç iki yerde ortaya çıkar: **bakımcının eli** (karıştırıcı) ve **tüketicinin sağlığı** (sıcaklık, yıkama). Puanlar V01–V09 kabullerine dayanır; gerçek makinede bulunmuş bir açık değildir.

Ölçek (LAB3 ders notu)

Puan	L — istismar kolaylığı	S — fiziksel sonuç	E — yolun dışa açıklığı
1	Zor; özel bilgi, fiziksel erişim veya zincir gerekir	Yaralanma yok	Yalnız fiziksel erişim
2	Orta; zayıf veya paylaşılan kimlik bilgisi yeter	Hafif, geri dönüşlü yaralanma	İşletme ağı veya süreli dış erişim
3	Kolay; varsayılan parola, doğrulama yok, hazır araç	Ağır/kalıcı yaralanma, ölüm, ciddi hastalık	İnternet veya sürekli açık dış yol

Görev — üç senaryo kurun ve puanlayın

Föy en az üç senaryo istiyor; bu makinede dört farklı fiziksel zincir çıktığı için dördü de puanlandı.

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R-01 Fırsatçı dış saldırgan → G01 sürekli açık uzak servis → G05'ten kapak/reset mantığını değiştirir (SF-01/SF-03) → bakımcı tanka elini sokarken karıştırıcı döner → ağır el/kol yaralanması	3	3	3	**27**	**1 · Kritik**
R-02 Meraklı içeriden kişi → G02 paylaşılan servis hesabı → sıcaklık/satış eşiğini değiştirir (SF-02) → uygunsuz sıcaklıkta süt satılır → tüketicide ciddi hastalık	2	3	1	**6**	**2 · Orta · S=3**
R-03 Tedarik zinciri → G04 değiştirilmiş servis paketi, G03 USB'den yüklenir → yıkama bitmeden "tamamlandı" bilgisi üretilir (SF-04) → kirli hattan satış → tüketicide ciddi hastalık	1	3	1	**3**	**3 · Düşük · S=3**
R-04 Hedefli saldırgan → G04 bakım projesi değiştirilir, G05'ten yerelde yüklenir → yeniden başlama engeli kalkar (SF-03) → enerji dönüşünde karıştırıcı kendiliğinden başlar → ağır yaralanma	1	3	1	**3**	**4 · Düşük · S=3**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

Puan gerekçeleri. R-01: varsayılan parola ve geniş yazma yetkisi (L3), karıştırıcıya kaptırma ile ağır yaralanma (S3), sürekli açık uzak yol (E3). R-02: paylaşılan servis şifresi gerekir (L2), koşullu ciddi biyolojik zarar (S3), yalnız makine başından (E1). R-03: paket değiştirme + fiziksel yükleme zinciri (L1), hijyen yetersizliğinin ürüne geçmesi (S3), son adım USB (E1). R-04: makineye özel proje bilgisi gerekir (L1), R-01 ile aynı yaralanma (S3), yerel bakım bağlantısı (E1).

Önlemler ve hedef puanlar

ID	Önerilen önlem	Sorumlu (A / R)	Hedef tarih	Hedef L/S/E
R-01	Uzak yazmayı kapat, LAB2 Görev B; H01/H03/H06	İşletmeci / OT-servis	06.12.2026	1/3/2 = 6
R-02	Servis rollerini ayır, eşik değişikliğine onay; H02	İşletmeci / gıda sorumlusu	04.02.2027	1/3/1 = 3
R-03	Yıkama–satış kilidi, imzalı paket; H04/H05	İşletmeci / servis + gıda	04.02.2027	1/3/1 = 3

ID	Önerilen önlem	Sorumlu (A / R)	Hedef tarih	Hedef L/S/E
R-04	Bağımsız yeniden başlama engeli, proje bütünlüğü; H03/H05	İşletmeci / servis + emniyet	04.02.2027	1/3/1 = 3

Tarihler ders notundaki 30/90 gün önerisinden hesaplandı; ölçülmüş artık risk değildir. **S=3 hiçbir önlemle otomatik olarak S=1'e düşürülmez**; düşen L ve E'dir, fiziksel zincirin kesildiği testle (KT01–KT07) ayrıca gösterilir.

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

R-01: Ders kabulündeki (V05/V06/V08) internetten, varsayılan parolayla ulaşılabilen ve sürekli açık servis yolu, tek adımda kapak korumasını kapatıp bakımcıyı ağır yaralanmaya açık bırakabiliyor.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet: **R-02 (6), R-03 (3), R-04 (3)**. Register'da ayrı bir **"S=3 izleme listesi"** sütunu tutulur: sahibi, hedef tarihi ve kapanış testi yazılır. Skor sıralamasından bağımsız olarak her gözden geçirmede ilk bakılan satırlardır. Önlem uygulanıp test kanıtı ya da yetkili yazılı kabul olmadan kapatılmaz.

> **Altın kural:** Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar? Bu Register'daki dört zincirin hepsi bir insanda bitiyor: bakımcı ya da sütü içen kişi.

Ders notu tartışma soruları

3 **Aynı kapıyı iki farklı profil kullanırsa skor değişir mi?** DERS NOTU

Profil adı değişti diye değişmez. Gereken beceri, erişim koşulu ya da etkilenen işlev değişiyorsa L veya E değişir ve bu ayrı gerekçeyle **ayrı bir satır** olarak yazılır.

4 **Skoru 27 ama S=1 olan mı, skoru 3 ama S=3 olan mı önce?** DERS NOTU

S=1 iken en yüksek skor 3 × 1 × 3 = **9** olur; 27/S=1 bu ölçekte mümkün değildir. Geçerli karşılaştırma 9/S=1 ile 3/S=3 arasındadır: üretim kaybı önemlidir ama **insana zarar veren S=3 gözden kaçırılmaz**, ayrı listede izlenir.

5 **Emniyete dokunmayan siber senaryo Register'a girmeli mi?** DERS NOTU

Girer, ama S=1 ile ve "emniyet bulgusu" diye sunulmadan. Örneğin satış geçmişinin değiştirilmesi bir ticari ve veri riskidir. Bir fiziksel zarar zinciri bulunursa ayrıca yazılır.

6 **Tedarikçinin "güvenli" beyanına ne kadar güvenirsiniz; hangi kanıt gerekir?** DERS NOTU

Beyan tek başına yetmez. Kurulu sürüm listesi, devre ve ağ şeması, yazma yetkilerinin dökümü ve ilgili test kayıtları gerekir. Bu ödevde firmadan belge istenmedi; eksik bilgi açık bırakıldı.

7 **Register ne zaman yeniden puanlanır?** DERS NOTU

Yeni bir açık yayımlandığında, yazılım veya ağ değiştiğinde, bakımdan sonra, bir olay yaşandığında ya da bir varsayım (V-kodu) yanlış çıktığında. Bunlar dışında planlı gözden geçirmede.

Ek sorularımız

8 **Otomatta internet bağlantısı hiç yoksa Register nasıl değişir?** EK SORU

R-01'in uzak yolu (G01) temel kurulumdan çıkar ve en kritik satır düşer. Ancak yerel ekran, USB ve bakım yolu kalır: R-02, R-03 ve R-04 geçerliliğini korur. "İnternet yok" demek "risk yok" demek değildir.

9 **Önlemden sonra skor düşmüyorsa önlem işe yaramamış mı olur?** EK SORU

Hayır. R-03 ve R-04 zaten L1/E1'de, ölçeğin tabanından aşağısı yok; R-02'de yalnız L 2'den 1'e iner. Önlemin değeri skorda değil, **zincirin kesildiğini gösteren testte** görünür (ör. KT04: yıkama sürerken satış talebi reddedildi). Kalan

belirsizlik ayrıca kaydedilir.

10 **Bu Register'da en çok tartışılabilecek puan hangisi?** EK SORU

R-02 ve R-03'ün **S=3** puanı. Sütün ne kadar süre, hangi sıcaklıkta kaldığı ve bulaşma koşulları bilinmiyor; ciddi biyolojik sonuç koşullu bir kabul. Gıda sorumlusu incelemesi S=2'ye indirebilir ya da S=3'te bırakabilir. Gerekçe her durumda yazılmalıdır.

11 **Yıkama yöntemi bilinmiyorsa R-03 nasıl yazılmalı?** EK SORU

Kimyasal, sıcak su ya da özel sensör uydurulmaz. R-03 yalnız "otomatik yıkamanın tamamlandı bilgisi satış iznini etkiliyor" kabulüne (V09) dayanır. Yıkamanın yeterli olup olmadığı hakkında saha sonucu vermez; V09 yanlış çıkarsa senaryo yeniden yazılır.

Varsayımlar

V01–V09 kullanıldı (Makine profili). Puanlar eğitim modeline aittir; gerçek makinede tespit edilmiş açık veya olay değildir.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur. Durum: **Taslak**.